

Manuale Operativo

OWASP Security Pipeline

Aggiornamento v1.3 — Aggiunta owasp-scan.sh pipeline script

Server: ubuntu@ta-server-openvas (51.75.196.150)

Team Tecnico | Versione 1.3 | Maggio 2026

1. Strumenti Operativi

Strumento	Versione	Categoria	Installazione
Nikto	2.1.5	DAST Web	apt
Semgrep	1.161.0	SAST	Docker
OWASP Dependency-Check	latest	SCA	Docker
GitLeaks	latest	Secrets	Docker
ZAP by Checkmarx	2.17.0	DAST Web	Docker (daemon mode)
DVWA	latest	Target test	Docker
OWASP ASTF	1.0-beta	DAST API	Maven/Java 21
WuppieFuzz	1.2.0	API Fuzzer	cargo
Falco	0.43.1	Runtime Security	apt + kmod
owasp-scan.sh	1.0	Pipeline script	Script bash

i INFO Workflow corretto: Semgrep+GitLeaks sul codice → Dependency-Check sulle dipendenze → Build → Nikto+ZAP+ASTF+WuppieFuzz su staging → owasp-scan.sh per automazione → Falco monitora in produzione 24/7.

2. owasp-scan.sh — Pipeline Automatizzata

Lo script owasp-scan.sh esegue automaticamente tutta la catena OWASP in sequenza. È lo strumento principale per le sessioni di test periodiche — basta modificare config.env e lanciare lo script.

2.1 Come funziona

Fase	Strumento	Cosa fa	Flag per saltare
1 — Secrets	GitLeaks	Scansiona tutta la storia git per secrets e API key	--skip-secrets
2 — SAST	Semgrep	Analisi statica codice con regole OWASP Top 10	--skip-sast
3 — SCA	Dependency-Check	CVE nelle librerie e dipendenze	--skip-sca
4 — DAST Web	Nikto + ZAP	Ricognizione e scan attivo web app	--skip-dast
5 — DAST API	ASTF + WuppieFuzz	OWASP API Top 10 + fuzzing stateful	--skip-api
6 — Network	OpenVAS	Scan infrastruttura e porte aperte	--skip-openvas
7 — Report	Python3	Report HTML unificato con tutti i findings	—

2.2 Avvio rapido

Pipeline completa

```
cd ~/owasp-scan
./owasp-scan.sh
```

Solo DAST — senza codice sorgente

```
./owasp-scan.sh --skip-sast --skip-secrets --skip-sca --skip-api --skip-openvas
```

Solo API

```
./owasp-scan.sh --skip-sast --skip-secrets --skip-sca --skip-dast --skip-openvas
```

Uno strumento specifico

```
./owasp-scan.sh --only zap
./owasp-scan.sh --only astf
./owasp-scan.sh --only nikto
```

2.3 Cambiare target

Per testare un target diverso modifica solo questi parametri in config.env:

```
nano ~/owasp-scan/config.env

# Cambia questi valori:
PROJECT_NAME="nome-progetto"
TARGET_URL="http://NUOVO_TARGET:PORT"
TARGET_API_URL="http://NUOVO_TARGET:API_PORT"
TARGET_IP="NUOVO_TARGET_IP"
SOURCE_DIR="/percorso/al/codice"
API_TOKEN="Bearer NUOVO_TOKEN"
```

2.4 Prerequisiti prima di lanciare

ATTENZIONE ZAP deve essere in modalità daemon (non webswing) per essere usato dallo script. Verificare sempre prima di lanciare la pipeline.

```
# 1. Verifica ZAP daemon attivo
curl -s
"http://localhost:8080/JSON/core/view/version/?apikey=dallaradallara20262026"
# Deve rispondere: {"version":"2.17.0"}

# 2. Se ZAP è in webswing, riavvialo in daemon
docker stop zap && docker rm zap
docker run -d --name zap -p 8080:8080 \
  ghcr.io/zaproxy/zaproxy:stable zap.sh -daemon \
  -host 0.0.0.0 -port 8080 \
  -config api.addrs.addr.name=.* \
  -config api.addrs.addr.regex=true \
  -config api.key=dallaradallara20262026

# 3. Verifica DVWA attivo (se è il target)
curl -s -o /dev/null -w "%{http_code}" http://172.17.0.1:8081
# Deve rispondere: 302
```

2.5 Visualizzare i report

```
# Trova ultimo report
LATEST=$(ls -td ~/owasp-scan/reports/*/ | head -1)

# Avvia server HTTP
cd $LATEST && python3 -m http.server 9999
# Browser: http://51.75.196.150:9999/index.html
```

2.6 Risultati test su DVWA (11/05/2026)

Strumento	Findings	Severity	Note
Nikto	21	Info/Low	Header mancanti, directory listing, config esposta
ZAP	276	61 Medium, 88 Low, 127 Info	Scan non autenticato — con auth salgono a High
TOTALE	297	0 High (scan non autenticato)	Durata totale: 11 secondi

3. Falco — Runtime Security

Falco monitora i container in tempo reale. È l'unico strumento che lavora dopo il deploy — in produzione, 24/7.

3.1 Avvio

ATTENZIONE Su KVM montare prima il BPF filesystem: `sudo mount -t bpf bpf /sys/fs/bpf`

```
sudo falco -o "engine.kind=kmod" > /var/log/falco-alerts.log 2>&1 &
sudo tail -f /var/log/syslog | grep
'falco:.*Warning\|falco:.*Notice\|falco:.*Critical'
```

3.2 Alert reali catturati

Alert	Severity	Trigger	Significato in prod
Sensitive file opened for reading	Warning	sudo cat /etc/shadow	Lettura file sensibile — indagare
Shell spawned in container	Notice	docker exec -it dvwa bash	Accesso interattivo container — compromissione

4. Workflow Operativo Completo

4.1 Sessione di test completa

```
# === PREREQUISITI ===
# Verifica ZAP daemon
curl -s
"http://localhost:8080/JSON/core/view/version/?apikey=dallaradallara20262026"
# Verifica Falco attivo
ps aux | grep falco | grep -v grep

# === CONFIGURA TARGET ===
cd ~/owasp-scan
nano config.env # modifica TARGET_URL, SOURCE_DIR, credenziali

# === LANCIA PIPELINE ===
nohup ./owasp-scan.sh > pipeline.log 2>&1 &
tail -f pipeline.log

# === VISUALIZZA REPORT ===
LATEST=$(ls -td ~/owasp-scan/reports/*/ | head -1)
cd $LATEST && python3 -m http.server 9999
# Browser: http://51.75.196.150:9999
```

4.2 Quando usare quale strumento

Scenario	Strumento	Come
Scan rapido web app	owasp-scan.sh --only nikto	60 secondi, nessuna config
Scan completo web app	owasp-scan.sh --skip-api --skip-openvas	Nikto + ZAP in sequenza automatica
Scan API REST	owasp-scan.sh --only astf	Richiede API_TOKEN in config.env
Analisi codice sorgente	owasp-scan.sh --skip-dast --skip-api	Richiede SOURCE_DIR in config.env
Pentest trimestrale completo	owasp-scan.sh	Pipeline completa — tutti gli strumenti
Monitoring container	Falco (sempre attivo)	Alert in /var/log/syslog
Scan infrastruttura	OpenVAS (interfaccia web)	http://IP-OPENVAS:9392

5. Troubleshooting

Problema	Causa	Soluzione
ZAP API non risponde su /JSON/	ZAP in modalità webswing, non daemon	Riavviare con <code>zap.sh -daemon</code> — vedi sezione 2.4
ZAP API 404 su porta 8080	Webswing intercetta le richieste	Usare modalità daemon sulla porta 8080
owasp-scan.sh: unbound variable	Bug array bash in heredoc Python	Aggiornare script alla versione corrente
Falco: Trying to open engine	BPF filesystem non montato su KVM	<code>sudo mount -t bpf bpf /sys/fs/bpf</code>
ASTF: invalid target release: 21	Maven usa Java 17	<code>export JAVA_HOME=/usr/lib/jvm/java-21-openjdk-amd64</code>
WuppieFuzz: command not found	PATH cargo non caricato	<code>source \$HOME/.cargo/env</code>
OpenVAS: 0% per ore	Port scan TCP+UDP troppo lento	Cambiare Port List in 'All TCP' — esclude UDP
Dep-Check: timeout NVD	Rate limit API NVD	Aggiungere <code>--nvdApiDelay 6000</code> e usare <code>nohup</code>